

PROVA FINAL

- Entrega Sem prazo
- Pontos 40
- Perguntas 10
- Limite de tempo 60 Minutos
- Tentativas permitidas 2

Instruções

INSTRUÇÕES DA PROVA FINAL

- A prova tem a duração de 60 minutos.
- Ao clicar em PROVA FINAL, no menu “Testes” você iniciará a prova. Ao acessar a página com as questões, o tempo começa a ser contado.
- A prova é composta de 10 (dez) questões objetivas, sendo 04 (quatro) pontos cada.
- Ao final do teste não se esqueça de enviá-lo, clicando no botão “ENVIAR TESTE”. Só utilize esse botão quando tiver finalizado a avaliação.
- Se necessário, durante a prova, entre em contato pelo link “Atendimento”.
- Você terá 02 (duas) tentativas e, caso necessite de uma nova, será preciso solicitar a prova extra, que requer pagamento de taxa adicional.

Atenção: Todas as provas iniciadas e que não houverem sido submetidas serão automaticamente encerradas pelo sistema transcorridos os 60 minutos de duração.

Boa prova!

Fazer o teste novamente

Histórico de tentativas

	Tentativa	Tempo	Pontuação
MAIS RECENTE	Tentativa 1	12 minutos	28 de 40

Pontuação desta tentativa: 28 de 40

Enviado 10 abr em 10:56

Esta tentativa levou 12 minutos.

Resposta incorreta



Pergunta 1

0 / 4 pts

Os modelos no contexto da engenharia de software evoluíram com o tempo para atender os diversos aspectos da dinâmica corporativa, assim como, as demandas do mercado. Cabe à organização

compreender a natureza do projeto de software para adotar o método ou metodologia adequada.

Uma organização está adotando a metodologia Waterfall para o desenvolvimento de um software que será implantado em um projeto de sistemas embarcados. Neste sentido, houve uma preocupação da adoção dos requisitos de segurança para o projeto em questão. Neste sentido, é correto afirmar que a MELHOR fase que os requisitos de segurança deve ser adotados é na fase de:

- ☐ Implementação
- ☐ Design do Sistema
- ☐ Implantação do Sistema
- ☒ Análise de Requisitos

Incorreto. Nesta fase, apenas são coletados os requisitos funcionais, não sendo possível definir requisitos de segurança específicos para o produto.

Resposta correta



Pergunta 2

4 / 4 pts

Há diversos métodos Ágeis que podem ser adotados pelas organizações. O XP Programming possui em sua instituição do método as seguintes práticas: **(i)** Práticas Sobre o Processo de Desenvolvimento, **(ii)** Práticas de Programação e **(iii)** Práticas de Gerenciamento de Projetos de Software.

No contexto de Práticas de Programação, dentre tais práticas, a que possui uma relação direta com a segurança da informação em DevSecOps, e que atualmente, evoluiu para formas mais convencionais de trabalho, contudo, adotando a mesma perspectiva em seu cerne, inclusive em aspectos de conformidade é:

- ☒ Programação Pareada

Correto. A Programação Pareada ou Revisão em Pares, atualmente é muito adotada como Revisão Manual de Código, que é uma parte importante da segurança da informação para avaliar fluxos de autenticação, autorização, criptografia, entre outros.

- ☐ Integração Contínua
- ☐ Desenvolvimento Dirigido por Testes
- ☐ Design Incremental

Resposta correta



Pergunta 3

4 / 4 pts

A proteção das aplicações Web é uma parte importante quando estamos lidando com falhas de segurança, assim como, técnicas adequadas para identificá-las.

Uma empresa no mesmo nicho de negócio que uma determinada empresa passou por um incidente de segurança em seu E-Commerce. O que foi observado é que o SAST e o DAST implementados não revelaram nenhuma vulnerabilidade, contudo, após a investigação, observou-se que havia uma

falha no fluxo de autorização da aplicação. Como lição aprendida a partir do alheio, no contexto da falha descoberta, quais os MELHORES métodos podem ser utilizados para detectar a falha e reduzir o risco?



A organização pode adotar WAF e RASP no modo de monitoramento, que podem ajudar a identificar este tipo de falha.



A organização pode adotar uma solução de Firewall e WAF (Web Application Firewall), que protegem a aplicação contra este tipo de falha.



A organização pode adotar revisão manual de código e Teste de Intrusão (Pentest), que podem ajudar a identificar este tipo de falha.

Correto. A revisão manual de código e Teste de Intrusão (Pentest), são mecanismos que podem ajudar a detectar este tipo de falha.



A organização pode adotar MFA e CAPTCHA, que irá reduzir o risco contra este tipo de falha.

Resposta correta



Pergunta 4

4 / 4 pts

As aplicações precisam de lidar com o tratamento de diversas informações sigilosas e sensíveis para a própria operacionalização. Informações como chave de criptografia simétrica, chave privada, senhas, entre outros, nos quais são majoritariamente cunhados como “segredos (ou secrets, em inglês)”, podem desembocar em grandes riscos para a organização se não forem tratados com segurança.

Das opções abaixo, qual seria a abordagem recomendada para lidar com a gestão de segredos em um Pipeline de desenvolvimento?



Adotar uma solução de Vault.

Correto. Tecnologias de Vault são amplamente recomendadas para lidar com segredos, e devidamente incorporado no Pipeline.



Usar apropriadamente arquivos .ENV (variáveis de ambiente) com restrições de acesso.



Armazenar os segredos em variáveis de ambiente.



Incluir os segredos no código-fonte garantindo rígido controle de acesso.

Resposta incorreta



Pergunta 5

0 / 4 pts

A remediação de vulnerabilidades é um dos pontos-chave da cultura DevSecOps, uma vez que lidamos diretamente com o débito técnico de segurança.

Você está apoiando a remediação de vulnerabilidades em um conjunto de bibliotecas críticas para o produto de software da empresa. O resultado de uma análise de risco, combinada juntamente com a informação do contexto do projeto de software foi sumarizado abaixo.

ID	Contexto	Biblioteca	CVSS	EPSS	Exploitable Path
1	Frontend	a.1.24.6	9.8	20%	TRUE
2	Frontend	b.6.8.32	9.8	40%	FALSE
3	Backend	c.8.10.38	9.8	90%	FALSE
4	Backend	d.4.6.2	9.8	80%	TRUE

Considerando o ID, a ordem de remediação das vulnerabilidades que MELHOR atenda a mitigação de riscos é:

- ☐ 2, 1, 3, 4.
- ☐ 3, 4, 2, 1.
- ☐ 1, 4, 2, 3.
- ☒ 4, 1, 3, 2.

Incorreto. Esta sequência não se firma no contexto de maior fator de exposição (Frontend, ou seja, público para a Internet), com uma gravidade técnica Crítica (9.8), que apesar de um EPSS variável, utiliza a função vulnerável da biblioteca. Estes princípios norteadores não são considerados para a análise em questão.

Resposta correta



Pergunta 6

4 / 4 pts

A proteção das aplicações Web é uma parte importante quando estamos lidando com falhas e exploração de vulnerabilidades.

Uma empresa está planejando lançar um produto Mobile. A preocupação é proteger o aplicativo nos dispositivos móveis de milhares de usuários. Entre as opções consideradas por um grupo de pessoas durante um brainstorm incluem-se as abaixo. Qual destas alternativas representa a MAIS eficaz?

- ☐ Mobile Device Management (MDM).
- ☐ Criptografia de dados em trânsito.
- ☒ RASP.

Correto. A tecnologia RASP é amplamente utilizada em dispositivos móveis para proteção do aplicativo. Muito utilizado para aplicativos de instituições financeiras.

- ☐ Criptografia de dados em repouso.

Resposta correta



Pergunta 7

4 / 4 pts

Testes de Software são amplamente adotados como parte das práticas do processo de DevSecOps, sendo abordados tanto os testes tradicionais da engenharia de software quanto aqueles da perspectiva de Test-Driven Security. Estes testes buscam tanto melhorar a qualidade do software quanto melhorar a postura de segurança do software.

Um novo integrante da equipe de desenvolvimento de software acabou de ingressar em uma Squad. Você foi nomeado como um Security Champion. Ao tomar contato com a trilha de desenvolvimento seguro, durante um questionário de compreensão dos temas iniciais, o novo integrante ficou com dúvida, pois não obteve êxito na seguinte questão de avaliação de conhecimento: “Quando o teste de segurança é realizado com conhecimento completo do código-fonte, como é chamado?”. Qual a alternativa correta o novo integrante deveria considerar?

- ☐ Teste Unitário
- ☐ Black-Box Testing
- ☒ White-Box Testing

Correto. Ferramentas de teste de segurança que possuem acesso ao código-fonte são denominadas White-Box Testing.

- ☐ Code-Review (Revisão de Código)

Resposta correta



Pergunta 8

4 / 4 pts

O CWE (Common Weakness Enumeration) é uma importante fonte de consulta e amplamente utilizada em Teste de Intrusão e ferramentas de segurança no contexto de DevSecOps. O CWE é um sistema que constitui de categorias para fraquezas e vulnerabilidades de hardware e software.

Uma organização está preocupada com uma fraqueza de software em particular enumerada no CWE (CWE-366) conhecida como condição de corrida, em que em sistemas *multithread*, por exemplo, o resultado do programa depende da ordem de execução de eventos que ocorrem simultaneamente, e que eventualmente, não podem ser controlados. Dos meios abaixo, o **MELHOR** método para identificar esta fraqueza é por:

- ☒ Static Application Security Testing (SAST)

Correto. O SAST é uma solução amplamente utilizada para identificar este tipo de fraqueza no software. O DAST também pode ser utilizado quando a aplicação está em execução, contudo, o CWE recomenda o SAST.

- ☐ Teste de Integração
- ☐ Teste Unitário

☐ Runtime Application Self-Protection (RASP)

Resposta correta



Pergunta 9

4 / 4 pts

A proteção das aplicações Web é uma parte importante quando estamos lidando com as fases de Operate e Monitor. São fases que preocupamos principalmente com a segurança do ambiente e da aplicação.

Uma empresa tem como objetivo proteger um aplicativo crítico de negócio e está com dúvidas referente se deve-se realizar o investimento na contratação de uma solução de WAF (Web Application Firewall) ou a adoção de uma tecnologia de RASP. Das afirmativas abaixo, qual apresenta a diferença fundamental e trata-se da alternativa correta que a empresa deve considerar para sanar sua dúvida?



Neste caso, a empresa deve adotar a solução de RASP, que irá proteger, exclusivamente, o aplicativo, uma vez que o RASP pode ser implantado dentro do aplicativo.

Correto. A tecnologia de RASP é utilizada para proteger especificamente o aplicativo.



Neste caso, a empresa deve adotar a solução de RASP, contudo, irá proteger exclusivamente o host/ativo que hospeda o aplicativo e o aplicativo.



Neste caso, a empresa deve adotar a solução de WAF, que irá proteger o host/ativo que hospeda o aplicativo e o aplicativo, uma vez que o WAF pode ser implantado dentro do aplicativo e do host que hospeda o aplicativo.



Neste caso, para a devida proteção do aplicativo, qualquer solução pode ser adotada, uma vez que possuem o mesmo propósito, sendo que os aspectos de investimento/custo que deve ser o fator decisório.

Resposta incorreta



Pergunta 10

0 / 4 pts

IAST (muitas vezes associado como a junção de SAST e DAST) é uma tecnologia que adota a instrumentação de software como forma de operação. Uma porção de código é adicionada ao aplicativo para coletar dados e realizar análises, integrando lógica de coleta ao código.

Das opções abaixo, é falsa a afirmativa:



As ferramentas de IAST não devem ser utilizadas em ambiente de Produção.

Incorreto. Esta é uma afirmação verdadeira quanto ao IAST.



No modelo IAST Ativo, é adotado um scanner da Web como parte do processo de teste.



As ferramentas IAST são ditas Gray-Box.



No modelo IAST Passivo, é adotado um módulo de DAST como parte do processo de teste e um agente de detecção.

Pontuação do teste: 28 de 40